

Critical Reflected Cross-Site Scripting (XSS) – Vulnerability Report

1. Title

Critical Reflected Cross-Site Scripting (XSS) in Search Functionality Leading to Arbitrary JavaScript Execution

2. Vulnerability Description

The application is vulnerable to Reflected Cross-Site Scripting (XSS) in the search functionality. User-supplied input entered into the search field is reflected in the application's response without proper output encoding or sanitization. This allows attacker-controlled JavaScript to execute in the victim's browser. Successful exploitation may allow attackers to execute arbitrary JavaScript, perform phishing attacks, modify page content, and act on behalf of authenticated users.

3. Affected URL

https://[redacted]
Affected Functionality: Search Bar

4. Steps to Reproduce

- Navigate to the affected website.
- Locate the search bar.
- Enter a valid XSS payload.
- Submit the search request.
- Observe that the payload is reflected in the response.
- JavaScript executes in the victim's browser, confirming Reflected XSS.

5. Impact

- Execute arbitrary JavaScript in users' browsers.
- Session hijacking (where applicable).
- Phishing and UI manipulation.
- Redirect users to malicious websites.
- Perform actions on behalf of authenticated users.

6. Remediation

- Implement contextual output encoding.
- Validate and sanitize all user input.
- Deploy a strict Content Security Policy (CSP).
- Avoid rendering untrusted data directly into HTML or JavaScript contexts.
- Perform regular secure code reviews and XSS testing.